

# Documentação Técnica e de Segurança — SIC

Documento preparado para atender à pendência apontada pela SOFTOPS no chamado de validação de segurança (CSEC), referente à liberação do SIC para instalação em estações de trabalho.

Versão do aplicativo na data deste levantamento: **1.3.3-beta** (src/core/version.py) Data do levantamento: 2026-08-19

## 1. Visão geral e propósito

O SIC é uma ferramenta **desktop de uso interno** das equipes de dados dos catálogos **Natura, Avon e Minha Loja (ML)**. Processa, audita e sincroniza arquivos de catálogo Salesforce Commerce Cloud / Demandware (Pricebook XML, Catalog XML, planilhas Excel), rodando **inteiramente na máquina do usuário**.

Módulos principais:

- **Auditor** — cruza Pricebook XML × Catalog XML × Excel (Grade de Ativação) para detectar divergências de preço, visibilidade, conflitos de canal, margem de segurança, integridade de kits/bundles, invasão cross-brand, entre outras 13 categorias de erro.
- **Detecção de marca** — classifica automaticamente arquivos como Natura, Avon ou ML, com salvaguarda específica para não confundir lojas Brasil com lojas de outros países da Natura&Co.
- **Exportador** — gera artefatos de exportação (Inventory XML por marca, categorização de presentes/kits).
- **Gerador / Sync / Cupom** — upload, validação, transformação e sincronização de catálogos; geração de XML de cupons Demandware.
- **"AI Agent"** — **não é um modelo de IA/LLM**; é um sistema baseado em regras fixas que traduz estatísticas do Auditor em um relatório de diagnóstico. Não há chamada a nenhum serviço de IA externo.
- **Certificado de Conformidade** — gera um PDF executivo quando a auditoria fecha sem divergências.

## 2. Arquitetura

Aplicação desktop nativa, **não é aplicação web nem serviço/API**.

- **UI**: PySide6 (Qt para Python) — pyproject.toml.
- **Camadas**: UI (PySide6) → Lógica de negócio (engines Python puro, src/core/) → Dados (SQLite local + sistema de arquivos do usuário).
- Processamento roda em background via QThread workers (src/workers/), sem travar a interface.
- Requer **Python >= 3.13** (build final é distribuído como executável autocontido via PyInstaller, o usuário final não precisa ter Python instalado).

## 3. Dependências externas

Gerenciadas via pyproject.toml / uv.lock:

| Pacote                                  | Versão resolvida |
|-----------------------------------------|------------------|
| certifi                                 | 2026.4.22        |
| lxml                                    | 6.1.0            |
| openpyxl                                | 3.1.5            |
| pandas                                  | 3.0.2            |
| pillow                                  | 12.2.0           |
| pyside6 (+ addons/essentials/shiboken6) | 6.11.0           |
| pytesseract                             | 0.3.13           |
| requests                                | 2.33.1           |

| Pacote     | Versão resolvida                                         |
|------------|----------------------------------------------------------|
| truststore | 0.10.4                                                   |
| fpdf2      | >=2.7.0 (usado para gerar o Certificado de Conformidade) |

Dependência de sistema (não-Python): **Tesseract OCR**, binário nativo instalado separadamente no host, usado apenas para funções de OCR.

Empacotamento: **PyInstaller** (build onedir) + **Inno Setup** (instalador Windows).

## 4. Dados tratados

- **Arquivos locais:** a aplicação só lê arquivos explicitamente selecionados pelo usuário (via diálogo ou arrastar-e-soltar) — XML Pricebook/Catalog Demandware e planilhas Excel.
- **Banco local SQLite (history.db):** grava metadados de operações (módulo, marca, ação, timestamp) para fins de histórico/auditoria interna do próprio uso da ferramenta — **não** grava o conteúdo dos catálogos processados. Fica local, na pasta de instalação do usuário, e não é versionado no repositório.
- **Configurações do usuário:** persistidas via QSettings — no Windows, no Registro (HKEY\_CURRENT\_USER\Software\SIC\SIC\_Suite).
- **Natureza dos dados de negócio processados:** SKUs, preços, categorias e flags de visibilidade de catálogos de produto Natura/Avon/ML. **Não há tratamento de dados pessoais (PII) de clientes finais** — os dados são de catálogo/produto/preço, não de pessoas.

## 5. Comunicação de rede

Superfície de rede é pequena e integralmente mapeada:

**Verificação/download de atualização** (pode ser desabilitada pelo usuário nas Configurações, eliminando toda comunicação de rede): - Consulta GET <https://api.github.com/repos/<repo>/releases/latest> para checar nova versão (sem enviar dados do usuário). - Download do instalador a partir de domínios github.com / objects.githubusercontent.com, somente mediante confirmação do usuário na interface. - Usa certifi como CA bundle, com fallback para o CA store nativo do Windows (truststore) em caso de erro de TLS/proxy corporativo.

**Webhook do Google Chat (opcional, acionado manualmente pelo usuário):** - O usuário pode configurar, em Configurações, uma URL de webhook do Google Chat do seu próprio espaço de trabalho. - Ao acionar "Enviar ao Google Chat" no módulo Auditor, a aplicação envia via PÔST um payload com **estatísticas agregadas** (total de divergências, contagem por marca, texto de diagnóstico) — **não envia SKUs individuais nem o conteúdo bruto dos arquivos**. - É a única saída de dados de negócio (ainda que agregados) para um serviço de terceiros, e é opcional/manual.

**Nenhum uso de SDK de nuvem** (AWS/Azure/GCP) e **nenhuma telemetria/analytics** são enviados pela aplicação.

## 6. Gestão de credenciais e segredos

- A aplicação **não possui login/autenticação de usuário** nem múltiplos perfis de acesso — é uma ferramenta local single-user.
- **Não há credenciais corporativas hardcoded em uso ativo** no código-fonte atual (nenhuma chave de API, senha ou connection string localizada em varredura do repositório).
- **Achado remediado:** o arquivo src/core/\_secret.py (gerado automaticamente por um script de build hoje removido, scripts/obfuscate\_key.py) foi commitado por engano no histórico do git.

Continha uma **chave de API do Google Gemini** (GEMINI\_API\_KEY), ofuscada por inversão de string + Base64 (não criptografia) — não um token do GitHub, como uma nota antiga no README chegava a sugerir. A chave era resquício de uma versão anterior do módulo "AI Agent" que testou integração com Gemini antes de ele se tornar o motor baseado em regras fixas que é hoje; não está em uso em nenhum ponto do runtime atual.

- **Ações de remediação já executadas (2026-08-19):** chave revogada no Google AI Studio; removida também da secret GEMINI\_API\_KEY em GitHub Actions; arquivo \_secret.py removido do rastreamento do git e adicionado ao .gitignore (commit 636a340).
- **Histórico do git já purgado** nas branches dev e main (reescrito e republicado no remoto) — o arquivo não existe mais em nenhum commit dessas branches. Branches antigas de feature/fix ainda contêm o arquivo no histórico, mas isso é apenas item de higiene, já que a chave foi revogada.
- Impacto para o usuário final da aplicação instalada: **nenhum** — a chave não concedia acesso a dados de catálogo/preço nem a sistemas internos Natura; o risco era de uso indevido de cota/faturamento da API Gemini, hoje eliminado.

## 7. Empacotamento, instalação e requisitos de permissão

- Instalador Windows via **Inno Setup**, configurado com PrivilegesRequired=lowest.
- **Instalação e atualização não exigem privilégios de administrador nem UAC** — instala em pasta de usuário (%LOCALAPPDATA%\SIC).
- Auto-update baixa o instalador mais recente do GitHub e o executa em modo silencioso (/SILENT /SUPPRESSMSGBOXES), sempre mediante confirmação explícita do usuário na interface antes de iniciar.
- O processo de auto-update usa um script PowerShell auxiliar (executado com -ExecutionPolicy Bypass, escopo local ao processo, não altera política do sistema) apenas para orquestrar a substituição do executável durante a atualização — padrão comum em aplicações desktop com auto-update.

## 8. Logging e auditoria

- **Não há telemetria, analytics ou coleta de métricas de uso enviada a terceiros.**
- Log técnico do processo de atualização gravado localmente em %TEMP%\sic\_update\_python.log (URLs de download, erros de conexão/SSL, códigos de saída) — não contém dados de catálogo nem segredos.
- O histórico de operações (history.db) funciona como log de auditoria interno do uso da própria ferramenta, permanece local e não é transmitido.

## 9. Resumo para avaliação de segurança

| Critério                                        | Situação                                                                                                                                                        |
|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Envia dados a servidores externos por padrão    | Não                                                                                                                                                             |
| Envio de dados de negócio a terceiros           | Apenas estatísticas agregadas, via webhook opcional configurado e acionado manualmente pelo próprio usuário                                                     |
| Trata dados pessoais de clientes finais (PII)   | Não                                                                                                                                                             |
| Requer privilégios de administrador             | Não                                                                                                                                                             |
| Possui login/autenticação própria               | Não (ferramenta local single-user)                                                                                                                              |
| Usa SDK de nuvem                                | Não                                                                                                                                                             |
| Telemetria/analytics                            | Não                                                                                                                                                             |
| Credenciais corporativas em uso ativo no código | Não                                                                                                                                                             |
| Pendência de segurança identificada             | Chave de API (Gemini) histórica no git (src/core/_secret.py) — revogada, removida do rastreamento e purgada do histórico de dev/main. Sem uso ativo em runtime. |

*Levantamento realizado por leitura direta do código-fonte do repositório (src/, pyproject.toml, uv.lock, sic.spec, sic.iss, .github/workflows/package.yml) e commits recentes. Citações de arquivo:linha detalhadas estão disponíveis mediante solicitação.*